

Individual or Teamwork of 2		
Student(s) identification		
Al Labade	Ayman	261239044

6 Points	Title of Incident:	Colonial Pipeline ransomware attack (2021)	
	Discovery date:	May 7, 2021, when Colonial Pipeline detected the ransomware on its IT systems.	
	Start date of Incident:	The intrusion appears to have started around the 6 or 7 th of May 2021, when attackers used stolen VPN credentials to access the network and deploy ransomware.	
	End date of incident:	Pipeline operations were restarted on May 12 2021 and fuel deliveries were largely back to normal roughly three days after. Though some impacts and follow-up work continued after that.	
	Organization affected:	Colonial Pipeline Company.	
		Number of employees	Roughly 800-1000 employees.
		Revenues	Annual revenues estimated in the billions
		Country	United States; headquarters in Alpharetta, Georgia.
		Line of business	Operation of major refined-products pipeline system transporting gasoline, diesel, and jet fuel from the Gulf Coast to the U.S. East Coast.
4	Cause of the incident:	Voluntary (malicious) attack. A ransomware group known as DarkSide used stolen VPN credentials to access Colonial’s IT network and then deployed ransomware.	
	Aspect affected:	Primarily availability, because Colonial shut down pipeline operations to contain the attack and to protect OT systems. Confidentiality was also affected, because about 100 GB of data was exfiltrated as part of a double-extortion tactic.	
10	Incident description		
	In May 2021, Colonial Pipeline, the largest refined-fuel pipeline in the U.S., was hit by a ransomware attack that targeted its business IT systems. Attackers associated with the DarkSide group accessed the network using stolen VPN credentials, encrypted critical business servers, and stole data for leverage. Although the operational technology controlling the physical pipeline was not directly encrypted, Colonial shut down all pipeline operations as a porecaution, which quickly disrupted fuel deliveries to much of the East Coast.		
10	Direct impacts		

	The shutdown of the pipeline for about six-day interrupted fuel deliveries to multiple states, causing gas shortages, long lines at stations, and localized price spikes because of panic buying. Colonial's core operations were impacted because it could not transport its usual volume of gasoline and jet fuel, which meant reduced revenue and pressure from customers and government agencies to restore service. Internally, staff had to work in "manual mode" and prioritize recovery instead of normal business, and the company's reputation for reliability took a massive hit.
5	Direct cost
	Public reporting indicates Colonial paid a ransom of about 75 bitcoin (around 4.4-5 million USD at the time) to obtain a decryption tool. Even after that, the company still had to spend money on incident response, external forensic support (e.g., Mandiant), system rebuilding, and legal and regulatory engagement. There were also business-interruption losses from several days of reduced or halted fuel shipments; although exact numbers are not public, the lost throughput on a pipeline that normally moves over 100 million gallons per day suggests significant revenue loss.
10	Incident timeline
	• Early May 2021: DarkSide gains access to Colonial's IT network using compromised VPN credentials. • May 7, 2021: Ransomware is deployed and detected; Colonial shuts down pipeline operations to contain the incident. • May 7-8, 2021: Colonial notifies federal authorities and engages a third-party incident response firm. • Within hours of discovery: Colonial pays roughly 75 bitcoins to obtain a decryption tool from the attackers. • May 9-10, 2021: U.S. government activated emergency measures and issues waivers to ease fuel transport by road and sea. • May 12, 2021: Colonial begins restarting pipeline operations. • May 15, 2021: Service returns to normal, though some regions still experience lingering supply effects. • June 2021: U.S. Department of Justice announces recovery of a large portion of the ransom funds.
5	Perpetrator
	The attack has been attributed to the DarkSide ransomware group, an Eastern-European cyber-criminal organization operating a ransomware-as-a-service model. The FBI publicly confirmed that DarkSide was responsible, so confidence in this attribution is high, although there is still limited public information about individual people behind the group.
5	Motivation
	The primary motivation appears to have been financial gain, consistent with typical ransomware operations. DarkSide is known for targeting organizations that can pay large ransoms and using double-extortion tactics (encryption plus data-leak threats), which fits the behavior in this incident. There is no strong public evidence that this was driven by political or ideological motives, even though it had national-security implications.
10	Vulnerabilities being exploited and techniques used by the attackers
	Attackers reportedly used previously stolen VPN credentials for an unused account that did not require multi-factor authentication, which allowed them access to Colonial's network remotely. Once inside, they performed reconnaissance, moved laterally, exfiltrated around 100 GB of data, and deployed DarkSide ransomware on Key IT systems. Weak identity and access management (no MFA, an active but unused VPN account) and insufficient network segmentation between critical business services created the conditions that allowed this attack to succeed.
10	Incident resolution

	To resolve the incident, Colonial isolated affected systems, shut down pipeline operations, engaged federal agencies and external cybersecurity experts, and ultimately paid the ransom to obtain a decryption key. However, the decryption tool was reportedly slow, so the company relied heavily on its own backups and recovery processes to rebuild systems, while gradually bringing the pipeline back online over several days. From a BC/DR perspective, operations were restored, but the reputational and regulatory consequences will continue for years, so the incident is not “entirely resolved” in a broader sense.
5	Communications to external parties
	Colonial issued several public statements during the week of the incident, but details about the cause and the ransom payment were limited at first. The company coordinated with the U.S. government, including the Department of Energy and the FBI, which helped manage public messaging and reassure consumers that fuel supplies would recover. Some critics argued that the communication was not fully transparent, especially about paying the ransom, but overall, there was a basic communication strategy aimed at avoiding panic.
10	Long-term impacts
	Long term, Colonial faced increased regulatory scrutiny, legal exposure, and costs related to improving its cybersecurity and resilience. The incident also pushed U.S. policymakers to treat ransomware against critical infrastructure as a national-security issue, leading to new guidance and expectations for pipeline operators and other critical sectors. Reputationally, Colonial is now a well-known case study in how cyberattacks can disrupt physical infrastructure, which may affect how partners and insurers evaluate its risk.
10	Lessons learned
	1. Colonial should have enforced stronger identity and access controls, especially MFA on remote-access VPN accounts and regular review of unused accounts. 2. Better network segmentation between IT and OT could have reduced the need for a full pipeline shutdown when only business systems were encrypted. 3. From a business continuity standpoint, more detailed scenario-based Business Impact Analysis (BIA) could have highlighted the risk of stopping all fuel flows due to an IT-only incident and driven investment in alternative manual or backup billing processes. 4. Strong, regularly tested disaster-recovery plans (including offline backups and clear recovery-time objectives) were essential; in fact, Colonial’s own backups ended up being more useful than the attacker’s decryption tool. 5. Overall, it is hard to say Colonial fully met “due diligence” expectations for a critical-infrastructure operator, given the lack of MFA and the size of the impact, but their ability to restore operations within about a week shows that some BC/DR capabilities were in place.